

Standards and Frameworks Alignment

Project: Enterprise Quantum Computing Platform — QFT Bank **Student:** Syed Muhammad Tahoor Ali **Diploma:** EduQual Level 6, Diploma in Artificial Intelligence Operations (ANPP-OP)

1. Purpose

Section 8 of the project specification requires the solution to demonstrate consideration of a set of international standards and frameworks, and to explain how each influences enterprise quantum computing adoption, financial-systems architecture, cryptographic governance, and long-term cybersecurity planning. This document provides that analysis. For each standard it states what the standard is, and how it applies concretely to this platform — not in the abstract, but to decisions actually made in the build.

2. ISO/IEC 23837 — Quantum Computing Concepts and Vocabulary

This standard establishes a common vocabulary for quantum computing. Its relevance to an enterprise adopting quantum methods is governance-level: when a bank's technical teams, risk officers, and executives discuss quantum initiatives, a shared and precise vocabulary prevents the miscommunication that derails early-stage technology programmes.

In this platform the influence is visible in the deliberate, consistent use of terms — qubit, gate, circuit, superposition, entanglement, QUBO, Ising Hamiltonian, variational algorithm — in both the interface and the documentation, and in the multi-framework module that demonstrates these concepts are framework-independent rather than tied to one vendor's terminology. For QFT Bank's Quantum Innovation Programme, adopting a standard vocabulary is the precondition for communicating quantum readiness to non-technical leadership.

3. NIST Post-Quantum Cryptography Standards

NIST's PQC standardisation produced the first quantum-resistant algorithms for general use, including ML-KEM (key encapsulation), ML-DSA and SLH-DSA (digital signatures), and HQC. These matter to a financial institution because a sufficiently large quantum computer running Shor's algorithm would break the public-key cryptography (RSA, elliptic-curve) that currently protects financial transactions.

This standard directly shapes Module 5. The module presents the NIST PQC catalogue, explains the quantum threat mechanism (phase estimation, the basis of Shor's algorithm), performs a simulated cryptographic inventory that scores systems by risk, and lays out a phased migration plan. The governance argument the module makes — that migration must begin before large-scale quantum computers exist, because encrypted data harvested today can be decrypted later ("harvest now, decrypt later") — is the core of cryptographic long-term planning for any bank.

4. NIST Cybersecurity Framework (CSF) 2.0

CSF 2.0 organises cybersecurity into functions: Govern, Identify, Protect, Detect, Respond, and Recover. Its value is as a structuring lens for an organisation's whole security posture rather than a checklist of controls.

The platform's security design maps onto several CSF functions. *Identify* is served by the PQC inventory scan and risk assessment. *Protect* is served by the least-privilege container hardening (non-root execution, dropped capabilities) and the single-entry-point network design. *Detect* is served by the build-time scanning layers (static analysis, dependency and container scanning) and by the monitoring stack. The scope-decisions document explicitly frames the choice not to deploy a full SIEM in CSF terms: build-time detection covers the vulnerability-detection function within the project's resource constraints, with a production SIEM identified as the enhancement that would extend Detect to runtime.

5. ISO/IEC 27001 — Information Security Management

ISO/IEC 27001 requires that security controls be selected on the basis of a risk assessment, with any exclusions justified. Its relevance here is methodological: it legitimises deciding *not* to implement a control, provided the decision follows from risk rather than oversight.

This principle is the backbone of the project's scope-decisions document, which records why four stack technologies were not deployed, tying each to a risk-and-resource judgement and naming the production alternative. That document is, in effect, a lightweight statement-of-applicability: it makes control selection explicit and defensible rather than leaving gaps unexplained.

6. ISO/IEC 27017 — Cloud Security

ISO/IEC 27017 extends information-security guidance to cloud services, covering the shared-responsibility model and cloud-specific controls. Although this platform runs on local Minikube rather than a public cloud, the design anticipates cloud deployment: the

container hardening, network segmentation, and Infrastructure-as-Code provisioning are all practices that carry directly into a cloud environment. The recommendation to provision a managed cluster (EKS/GKE) via the same Terraform workflow is where 27017's shared-responsibility considerations would become operative.

7. ISO/IEC 27018 — Protection of Personally Identifiable Information

ISO/IEC 27018 addresses the protection of PII in cloud services. Its relevance to this specific platform is bounded and worth stating plainly: the platform uses only simulated financial data and contains no personal information by design. This is itself a privacy-by-design decision appropriate to a proof-of-concept. In a production deployment handling real customer portfolios, 27018 would govern data handling, and the identity layer deliberately deferred here (Keycloak) would become mandatory to control access to PII.

8. COBIT 2019

COBIT is a governance framework aligning IT with business objectives, emphasising that technology investment should be traceable to business value. Its influence on this project is in the framing: every module answers a business need identified by QFT Bank's Quantum Innovation Programme — portfolio optimization, algorithm capability, executive decision support, and cryptographic readiness — rather than demonstrating technology for its own sake. The Executive Dashboard exists specifically to translate technical activity into the business-level KPIs COBIT would expect leadership to govern by.

9. ITIL 4

ITIL 4 provides service-management guidance, including guiding principles such as "start where you are," "progress iteratively," and "optimise and automate." These principles directly justify the project's engineering approach: deliver working capability within real constraints rather than deferring delivery pending complete tooling, and automate what is automated (the CI/CD pipeline, the Infrastructure-as-Code provisioning) while being honest about what is not yet complete. The graceful-degradation persistence design is an ITIL-aligned service decision — it prioritises availability of the service over strict persistence when the two conflict.

10. OWASP Top 10

The OWASP Top 10 catalogues the most critical web-application security risks. The platform's practices address several: input is validated by Pydantic schemas before any processing (mitigating injection and malformed-input risks); the backend runs with least privilege; dependencies are scanned for known vulnerabilities (addressing vulnerable-and-outdated-components risk); and the build image is scanned by Trivy. Static analysis by Bandit provides an additional application-security layer. These are integrated into the pipeline so that the checks run on every build rather than as a one-off audit.

11. CIS Critical Security Controls

The CIS Controls are a prioritised set of defensive actions, explicitly tiered by implementation group so that organisations implement what their resources support. This tiering is directly relevant: it acknowledges that a proof-of-concept implements a foundational subset rather than the full control set. The platform implements several foundational controls — inventory awareness (the PQC inventory scan), secure configuration (the hardened container and the OPA policy gate enforcing manifest baselines), and continuous vulnerability management (the scanning pipeline). The CIS framing is also what makes the documented exclusions defensible: implementing the controls the available resources support, and recording the rest, is precisely the model CIS endorses.

12. Summary

Taken together, these standards influence the platform at three levels. At the **governance** level, ISO 23837, COBIT, and CSF 2.0 shape how quantum capability is communicated and justified to leadership. At the **security and cryptographic** level, the NIST PQC standards, ISO 27001/27017/27018, OWASP, and CIS shape both the implemented controls and the honest documentation of what was deferred. At the **service-delivery** level, ITIL 4 shapes the decision to deliver resilient, working capability within constraints. The consistent theme is that the standards are used not as a compliance checklist but as a set of lenses that make the project's engineering decisions explicit and defensible — which is the posture a real enterprise quantum adoption programme would require.